

Detect Web Application Vulnerabilities Using Various Security Tools

Execution mode	Authorized, isolated training lab; no public systems were targeted.
Output status	Representative/sanitized lab output recorded for submission. Replace with instructor-required screenshots if a live lab run is performed.

Aim

Use more than one automated security tool to classify and compare web-application findings.

Theory

Tool coverage differs: Nikto emphasizes web-server checks, while ZAP crawls and tests application behavior. This is a sanitized comparison against an OWASP Juice Shop-style training target.

Tools and Lab Scope

- OWASP ZAP
- Nikto
- Juice Shop/DVWA training target
- HTML/PDF report export

Procedure and Recorded Execution

Step 1. Run Nikto - Perform a bounded server check against the authorized training endpoint.

```
nikto -h http://192.168.56.60:3000  
findings: 3 informational/low
```

Step 2. Run ZAP automated scan - Spider and active-scan the same lab URL.

```
ZAP scan complete  
URLs: 86  
alerts: 9
```

Step 3. Classify findings - Group results into high, medium, low, and informational categories and remove duplicates.

Step 4. Generate the report - Export the sanitized report and record mitigation owners.

Cross-tool vulnerability output

ZAP provided broader application coverage, while Nikto corroborated server-header and security-header observations. No unverified alert was promoted to a confirmed high-risk issue.

Risk	ZAP result	Nikto result	Disposition
High	No confirmed high-risk issue in this run	None	Manual review required
Medium	Reflected input validation weakness	None	Fix encoding and retest
Low	Missing X-Frame-Options/CSP	Missing hardening headers	Set security headers
Info	Technology/version disclosure	Server banner disclosure	Minimize banners

Result

The comparison shows why professional assessments use complementary tools and manual validation. The final report is actionable because each finding has a risk, evidence, and remediation.

Safety and Submission Notes

- Scan only authorized training targets.
- Do not equate an alert count with security quality.
- Track duplicates and validate with reproducible evidence.

Viva Questions and Answers

Scanner vs manual test?

A scanner automates broad checks; a manual test uses human reasoning to validate impact and business context.

What does ZAP Spider do?

It discovers routes before active tests are sent.

Why false positives?

Heuristics may misread normal application behavior as a vulnerability.

Two security headers?

Content-Security-Policy and Strict-Transport-Security; X-Frame-Options is also common.

Why authorization matters?

Scanning can create load and test payloads that affect data or state.